TESTES DE SEGURANÇA

Testes de invasão executados. "Resultado" refere-se ao sistema em MODO SEGURO (entrega padrão). Entre parênteses, o comportamento quando a falha é ligada no modo vulnerável.

ID	TIPO	Descrição	Resultado	Sugestão de Correção (caso teste positivo)
1	FERRAMENTA	Testar se os hashes armazenados podem ser quebrados pelo CrackStation	Negativo — senhas em bcrypt (custo 12) não são quebradas (Positivo se armazenadas em SHA1)	Migrar hashes para bcrypt/argon2 e enviar e-mail ao usuário exigindo a troca de senha
2	MANUAL	SQL Injection no login com payload ' OR '1'='1' --	Negativo — retorna HTTP 401 (Positivo no modo vulnerável: autentica como admin)	Usar queries parametrizadas (prepared statements) em todas as consultas
3	FERRAMENTA	SQL Injection automatizado na busca de produtos (sqlmap / UNION SELECT)	Negativo — parâmetro tratado com placeholder (Positivo no modo vulnerável: extrai e-mails e hashes)	Parametrizar a busca (LIKE ?) e validar/escapar a entrada
4	MANUAL	IDOR — acessar /pedidos/ID de outro usuário	Negativo — HTTP 403 (Positivo no modo vulnerável: exibe pedido alheio)	Verificar a posse do recurso (comprador_id) antes de exibir
5	MANUAL	XSS armazenado em avaliação de produto (<script>...)	Negativo — saída escapada + CSP (Positivo no modo vulnerável: script executa)	Escapar a saída (output encoding) e aplicar Content-Security-Policy
6	MANUAL	Força bruta no login (tentativas repetidas de senha)	Negativo — bloqueio após 5 tentativas e HTTP 429 (Positivo se rate limit desligado)	Rate limit por IP + bloqueio temporário de conta + MFA
7	MANUAL	CSRF — enviar POST de ação sem o token	Negativo — HTTP 403 (token CSRF obrigatório)	Token anti-CSRF por sessão e cookies SameSite
8	MANUAL	Exposição de dados sensíveis no banco (CPF, cartão)	Negativo — CPF/cartão cifrados (AES-256-GCM); CVV não armazenado	Cifrar dados sensíveis em repouso; nunca armazenar CVV
9	FERRAMENTA	Varredura de vulnerabilidades do servidor (Nessus)	A preencher na aula conforme os achados do scan	Aplicar patches, fechar serviços e corrigir configurações apontadas
10	FERRAMENTA	Mapeamento de portas/serviços expostos (nmap)	A preencher na aula (ex.: 80/443 abertas; 3306 fechada)	Fechar portas desnecessárias e restringir no firewall (ufw)
11	MANUAL	Verificar cabeçalhos de segurança (HSTS, CSP, X-Frame-Options)	Negativo (sem falha) — cabeçalhos presentes via Helmet/nginx	Manter Helmet e cabeçalhos no proxy; revisar CSP periodicamente
12	MANUAL	Mensagens de erro verbosas (stack/SQL ao cliente)	Negativo — erro genérico ao cliente; detalhe só no log	Desabilitar stack trace em produção; logar internamente